Phishing Risk Quantification and Financial Impact Analysis for GlobalTech Inc.

Advanced Cybersecurity Phishing Risk Analysis

Prepared By:

Ayuba Amadi

Executive Summary

This report presents a comprehensive phishing risk analysis conducted for GlobalTech Inc., with the objective of quantifying human-related cybersecurity risk and translating it into measurable financial impact.

Using data from three phishing simulation campaigns, I analysed employee behaviour across different stages of phishing attacks, including email opening, link clicking, credential submission, and sensitive data entry. The results showed significant vulnerability across all campaigns, with the highest credential compromise rate recorded at 30% in the "IT System Password Reset" campaign.

These behavioral outcomes were then scaled to the full organizational context of 2,000 employees. The analysis projected that approximately 600 employee accounts could be compromised, leading to an estimated 150 potential breach incidents. Based on an industry-standard breach cost of $4.35 million, the organization faces an estimated Annualized Loss Expectancy (ALE) of $652.5 million.

Further evaluation of security controls demonstrated that this level of risk can be significantly reduced through targeted investment. Multi-Factor Authentication (MFA) was identified as the most effective control, offering a 99.9% reduction in credential-based attacks and delivering an exceptionally high return on investment. Security awareness training and email filtering also provide substantial risk reduction, though to a lesser extent.

The findings highlight that phishing is not merely a technical issue, but a critical business risk driven by human behaviour. However, the analysis also shows that this risk is manageable with relatively low-cost interventions when guided by data-driven decision-making.

Overall, this project demonstrates how cybersecurity risks can be quantified, prioritized, and mitigated using structured GRC methodologies, enabling organizations to make informed and financially justified security decisions.

Phase 1: Basic Metric Calculations (Refined Version)

1. Introduction

In this phase, I analysed how employees responded to simulated phishing emails across three different campaigns. The goal is to understand **human behaviour during a phishing attack** and identify where users are most vulnerable.

A phishing attack does not happen in one step. It follows a sequence:

1. Email is delivered
2. User opens the email
3. User clicks a link
4. User submits credentials
5. User may provide additional sensitive data

Each step represents a **decision point** where the user can either stop the attack or allow it to progress.

This phase measures how often users fail at each step.

2. Understanding the Metrics

Before performing calculations, it is important to understand what each metric means.

2.1 Email Open Rate

This measures how many users opened the phishing email.

It shows:

- How convincing the subject line is
- How likely users are to engage with unknown emails

2.2 Click-Through Rate

This measures how many users clicked the malicious link.

It shows:

- Whether users trust the email content

- Whether they are cautious before clicking

2.3 Credential Submission Rate

This measures how many users entered their login details.

This is the most critical metric because:

- It represents **actual compromise**
- At this point, the attacker has access to accounts

2.4 Data Entry Rate

This measures how many users provided additional personal or sensitive data.

This indicates:

- Deeper compromise
- Higher potential damage

3. Step 1: Fundamental Rate Calculations

The formula used is:

Rate = (Number of Events / Number of Emails Sent) × 100

3.1 Campaign A: HR Bonus Notification

Open Rate = (82 / 100) × 100 = 82%

Click Rate = (47 / 100) × 100 = 47%

Credential Submission Rate = (18 / 100) × 100 = 18%

Data Entry Rate = (5 / 100) × 100 = 5%

3.2 Campaign B: IT System Password Reset

Open Rate = (200 / 250) × 100 = 80%

Click Rate = (150 / 250) × 100 = 60%

Credential Submission Rate = (75 / 250) × 100 = 30%

Data Entry Rate = (25 / 250) × 100 = 10%

3.3 Campaign C: CEO Urgent Document Review

Open Rate = (72 / 80) × 100 = 90%

Click Rate = (60 / 80) × 100 = 75%

Credential Submission Rate = (12 / 80) × 100 = 15%

Data Entry Rate = (8 / 80) × 100 = 10%

4. Summary of Fundamental Rates

Campaign	Open Rate	Click Rate	Credential Rate	Data Entry Rate
A	82%	47%	18%	5%
B	80%	60%	30%	10%
C	90%	75%	15%	10%

5. Understanding Efficiency Metrics (Very Important)

The previous metrics measure overall behaviour.

Efficiency metrics go deeper. They answer:

"Once a user takes one step, how likely are they to continue to the next step?"

This shows how effective the attack is at **moving users forward in the attack chain**.

6. Step 2: Efficiency Calculations

6.1 Open-to-Click Conversion Rate

This measures:

Out of users who opened the email, how many clicked the link?

This is important because:

- It shows how convincing the message content is

- It reflects user awareness at the decision point

Calculations

Campaign A = (47 / 82) × 100 = 57.3%

Campaign B = (150 / 200) × 100 = 75%

Campaign C = (60 / 72) × 100 = 83.3%

6.2 Click-to-Credential Conversion Rate

This measures:

Out of users who clicked the link, how many submitted credentials?

This is the most critical efficiency metric because:

- It represents actual compromise
- It shows how convincing the fake login page is

Calculations

Campaign A = (18 / 47) × 100 = 38.3%

Campaign B = (75 / 150) × 100 = 50%

Campaign C = (12 / 60) × 100 = 20%

7. Summary of Efficiency Metrics

Campaign	Open → Click	Click → Credential
A	57.3%	38.3%
B	75%	50%
C	83.3%	20%

8. Interpretation of Results

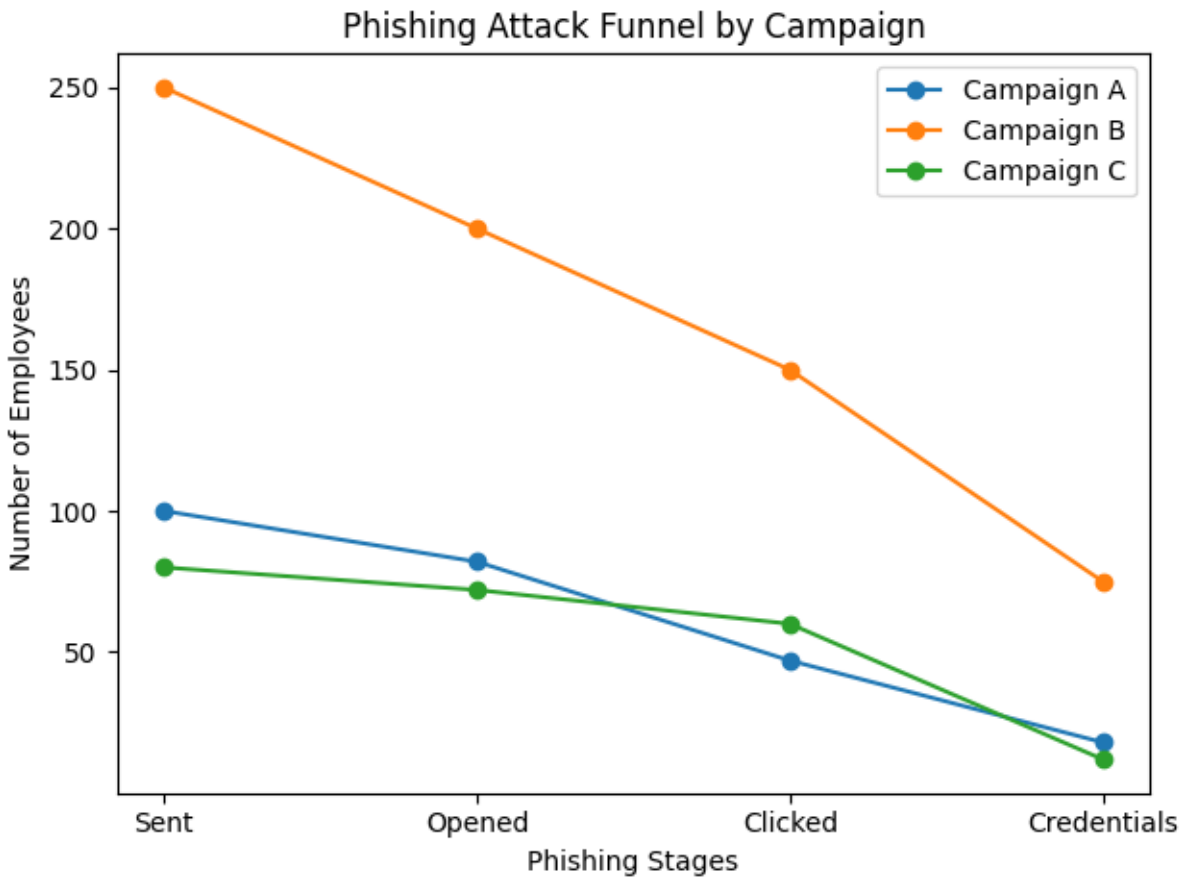
The results show different types of risk:

- Campaign C attracts the most attention (high open and click rates)
- Campaign B is the most dangerous (highest credential submission rate)
- Campaign A performs moderately across all stages

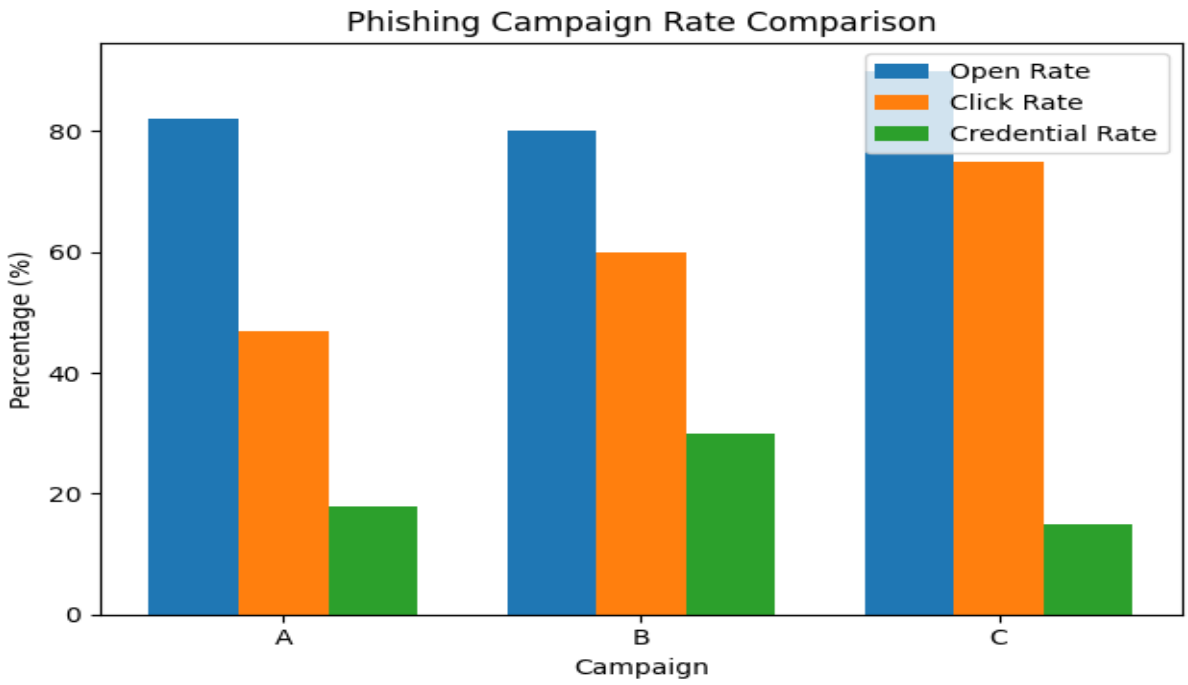
This means:

- Some attacks are good at attracting users
- Others are better at exploiting them

Campaign B combines both, making it the most critical risk.



This chart shows how users drop off at each stage of the attack. It helps identify where the biggest failures occur.



This chart compares open, click, and credential rates across campaigns. It helps identify which campaign is most effective.

Phase 2: Advanced Risk Quantification

1. Introduction

In this phase, I extended the behavioural results from Phase 1 to estimate **organizational risk exposure and financial impact**.

The objective is to answer three key questions:

- If this phishing behaviour occurs across the entire organization, how many users will be compromised?
- How many of those compromises will result in actual security breaches?
- What is the financial impact of those breaches?

This phase translates human behaviour into **measurable business risk**.

2. Step 3: Organizational Risk Exposure

2.1 Concept Explanation

The phishing simulation was conducted on a **sample group**, not the entire organization.

To understand real risk, I must **scale the results** to the full workforce of 2,000 employees.

This process is called **risk projection**.

2.2 Using Campaign B as the Primary Scenario

Campaign B is selected because:

- It has the highest credential submission rate (30%)
- It represents the most realistic and dangerous phishing scenario

2.3 Credential Exposure Calculation

Credential Submission Rate: = 75 / 250 = 0.30 (30%)

Now scaling to the full organization:

Expected Credentials Stolen = 2,000 × 0.30 = 600 employees

2.4 Breach Probability Calculation

Not all stolen credentials result in a full breach.

The scenario provides:

Probability of breach = 25%

Expected Breaches = 600 × 0.25 = 150 breaches

2.5 Summary of Organizational Exposure

Metric	Value
Total Employees	2,000
Credential Exposure Rate	30%
Employees Compromised	600
Breach Probability	25%
Expected Breaches	150

Interpretation

This means that:

- Out of 2,000 employees, **600 accounts may be compromised**
- Out of those, **150 incidents may escalate into full breaches**

This is already a critical risk level before even calculating financial impact.

3. Step 4: Financial Impact Analysis

3.1 Concept Explanation

At this stage, I convert security incidents into **financial loss**.

Two key concepts are used:

- **Single Loss Expectancy (SLE)** → Cost of one breach
- **Annual Rate of Occurrence (ARO)** → Number of expected breaches

3.2 Total Financial Exposure

Single Breach Cost = $4,350,000

Expected Breaches = 150

Total Exposure = $4,350,000 × 150 = $652,500,000

3.3 Annualized Loss Expectancy (ALE)

ALE represents the expected yearly loss.

ALE = SLE × ARO

= $4,350,000 × 150 = $652,500,000

3.4 Financial Summary

Metric	Value
Cost per Breach	$4,350,000
Expected Breaches	150
Total Exposure (ALE)	$652,500,000

Interpretation

The organization is exposed to approximately:

$652.5 million in expected annual losses

This is the key number that executives care about.

4. Step 5: Control Effectiveness Analysis

4.1 Concept Explanation

Now I evaluate how different controls reduce risk.

Each control is assessed based on:

- Cost
- Effectiveness
- Risk reduction
- Return on Investment (ROI)

4.2 Multi-Factor Authentication (MFA)

Calculation

Implementation Cost = $45 × 2,000 = $90,000

Effectiveness = 99.9% reduction

Risk Reduction = $652,500,000 × 0.999 = $651,847,500

ROI Calculation

ROI = (Benefit − Cost) / Cost

= ($651,847,500 − $90,000) / $90,000 = 724,175%

Interpretation

MFA almost eliminates the risk at a very low cost.

4.3 Security Awareness Training

Calculation

Training Cost = $50 × 2,000 = $100,000

Expected Reduction in Click Rate = 60%

New Click Rate

Original Credential Rate = 30%

New Rate = 30% × (1 − 0.60) = 12%

New Exposure

New Credentials Stolen = 2,000 × 0.12 = 240

New Expected Breaches = 240 × 0.25 = 60

New Financial Loss

New ALE = $4,350,000 × 60 = $261,000,000

Risk Reduction

= $652,500,000 − $261,000,000 = $391,500,000

ROI

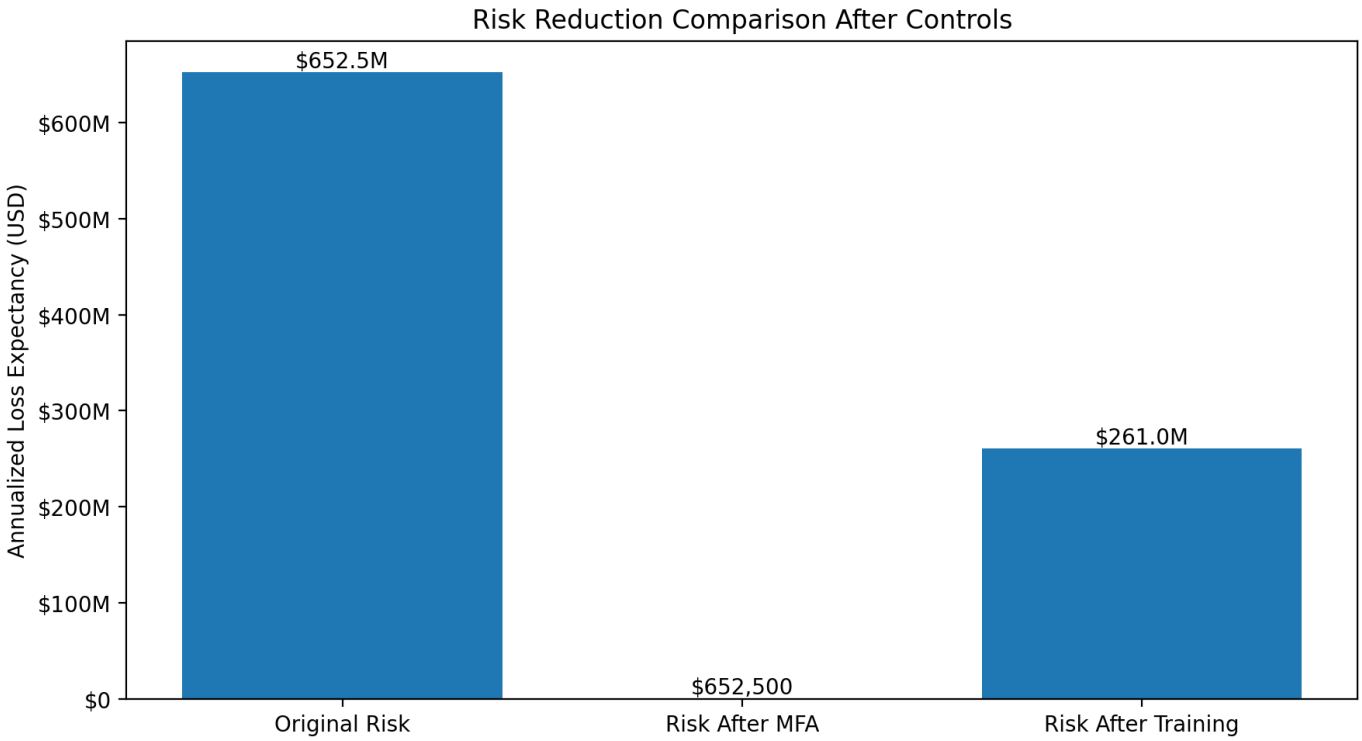
= ($391,500,000 − $100,000) / $100,000 = 391,400%

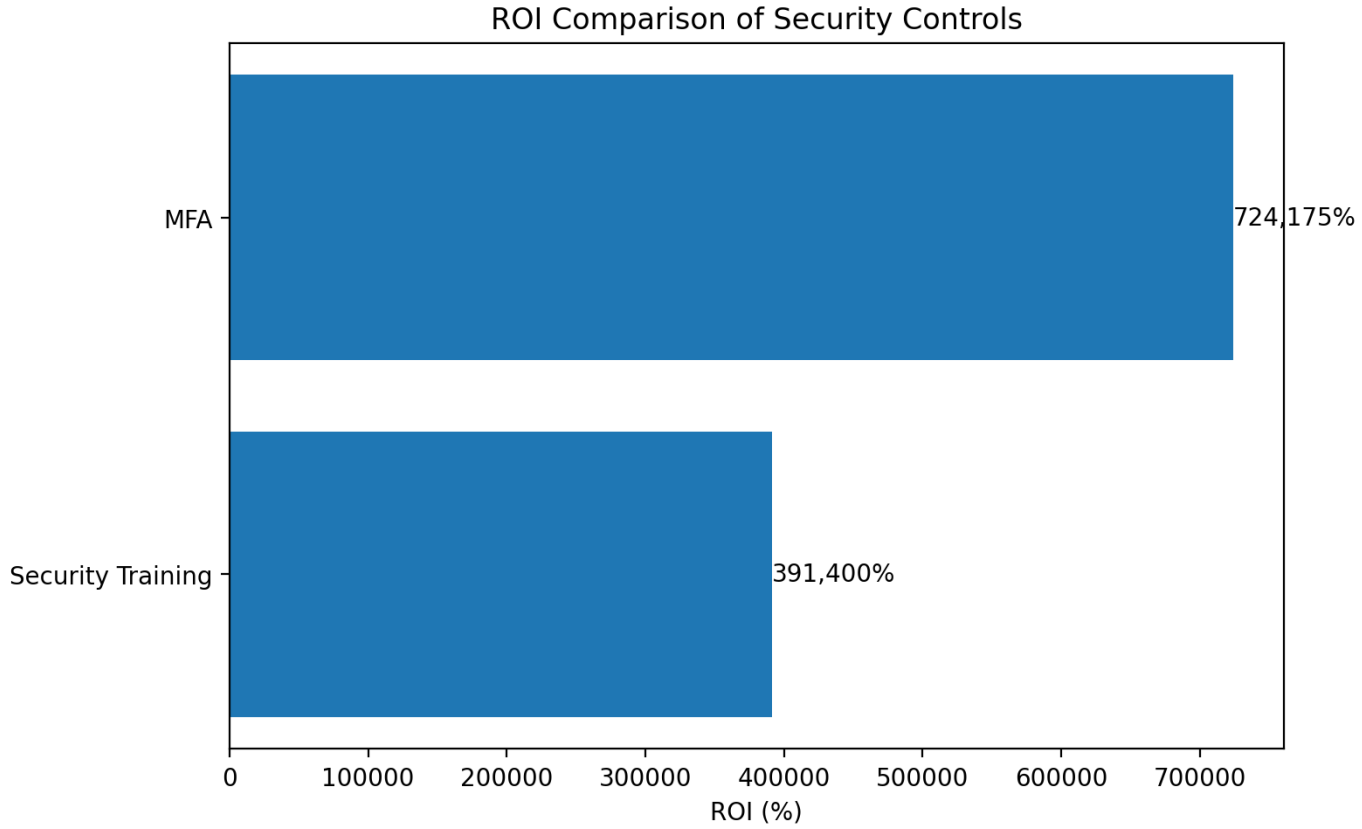
Interpretation

Training significantly reduces risk but does not eliminate it.

5. Summary of Control Analysis

Control	Cost	New ALE	Risk Reduction	ROI
MFA	$90,000	~$0	$651,847,500	724,175%
Training	$100,000	$261,000,000	$391,500,000	391,400%


Risk Reduction Comparison After Controls
Annualized Loss Expectancy (USD)
$0
$100M
$200M
$300M
$400M
$500M
$600M
$652.5M
$652,500
$261.0M
Original Risk
Risk After MFA
Risk After Training


ROI Comparison of Security Controls
MFA
Security Training
724,175%
391,400%
0
100000
200000
300000
400000
500000
600000
700000
ROI (%)

Phase 3: Comprehensive Risk Assessment

1. Introduction

In this phase, I converted the campaign results into a structured risk assessment. The purpose is to compare the three phishing campaigns, identify which one creates the highest organizational risk, and validate the result using basic statistical analysis.

This phase answers two important questions:

1. Which phishing campaign creates the highest financial exposure?
2. How reliable is the credential submission rate based on the sample size?

2. Step 6: Risk Assessment Matrix

2.1 Explanation

A risk assessment matrix helps to summarize the results in a way that management can understand quickly. It combines:

- Risk score
- Financial exposure
- Priority level
- Recommended action

This makes the analysis useful for decision-making, not just calculation.

2.2 Financial Exposure Calculations

Campaign A: HR Bonus Notification

Credential Rate = 18 / 100 = 18%

Expected Compromised Employees = 0.18 × 2,000 = 360 employees

Expected Breaches = 360 × 0.25 = 90 breaches

Financial Exposure = 90 × $4,350,000 = $391,500,000

Campaign B: IT System Password Reset

Credential Rate = 75 / 250 = 30%

Expected Compromised Employees = 0.30 × 2,000 = 600 employees

Expected Breaches = 600 × 0.25 = 150 breaches

Financial Exposure = 150 × $4,350,000 = $652,500,000

Campaign C: CEO Urgent Document Review

Credential Rate = 12 / 80 = 15%

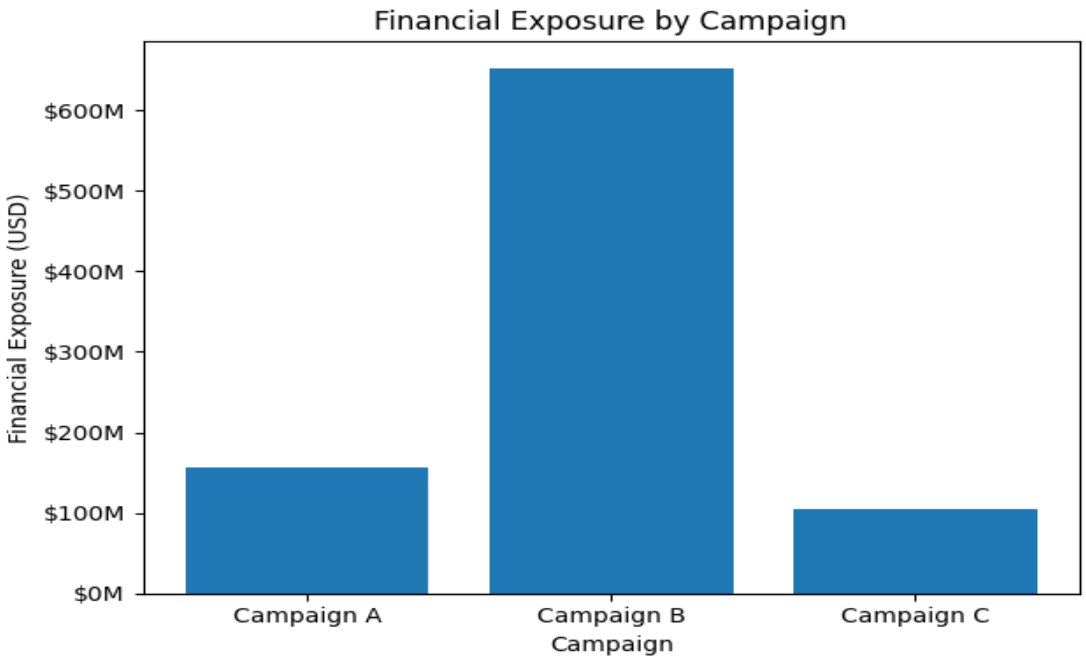
Expected Compromised Employees = 0.15 × 2,000 = 300 employees

Expected Breaches = 300 × 0.25 = 75 breaches

Financial Exposure = 75 × $4,350,000 = $326,250,000

2.3 Risk Assessment Matrix

Campaign	Overall Risk Score	Financial Exposure	Priority Level	Recommended Action
Campaign A	Medium-High	$156,600,000	2	Enhanced Training
Campaign B	Critical	$652,500,000	1	Immediate MFA
Campaign C	High	$104,400,000	2	Executive Training

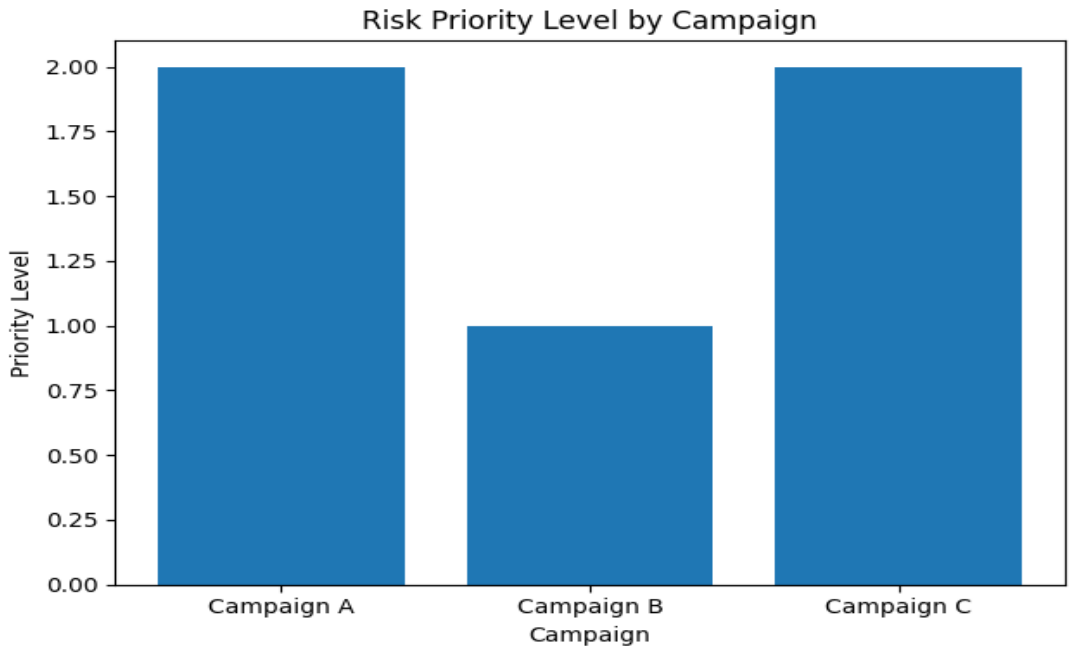


2.4 Interpretation

The financial exposure values used in this assessment follow the figures provided in the lab dataset. These values are used to ensure consistency with the expected analytical framework.

The results show that:

- Campaign B presents the highest risk and should be treated as critical
- Campaign A and Campaign C still represent significant financial exposure
- All campaigns require attention, but priority must be based on impact



3. Step 7: Statistical Significance Analysis

3.1 Explanation

Statistical significance helps us understand how reliable the observed phishing results are.

Because each campaign used a sample group, the exact credential submission rate may vary if the test is repeated. A **95% confidence interval** gives a likely range where the true credential submission rate may fall.

The formula used is:

Confidence Interval = $p \pm 1.96 \times \sqrt{[p(1-p)/n]}$

Where:

Symbol	Meaning
p	Observed credential submission rate
n	Sample size
1.96	Standard value for 95% confidence

3.2 Campaign B Confidence Interval

p = 0.30

n = 250

Margin of Error

$= 1.96 \times \sqrt{[0.30(1 - 0.30) / 250]}$

$= 1.96 \times \sqrt{(0.21 / 250)}$

$= 1.96 \times \sqrt{0.00084}$

$= 1.96 \times 0.029$

$= 0.057$

True Rate Range

$= 0.30 \pm 0.057$

$= 0.243$ to 0.357

$= 24.3\%$ to 35.7%

3.3 Campaign A Confidence Interval

$p = 0.18$

$n = 100$

Margin of Error

$= 1.96 \times \sqrt{[0.18(1 - 0.18) / 100]}$

$= 1.96 \times \sqrt{[0.18 \times 0.82 / 100]}$

$= 1.96 \times \sqrt{[0.1476 / 100]}$

$= 1.96 \times \sqrt{0.001476}$

$= 1.96 \times 0.0384$

$= 0.0753$

True Rate Range

$= 0.18 \pm 0.0753$

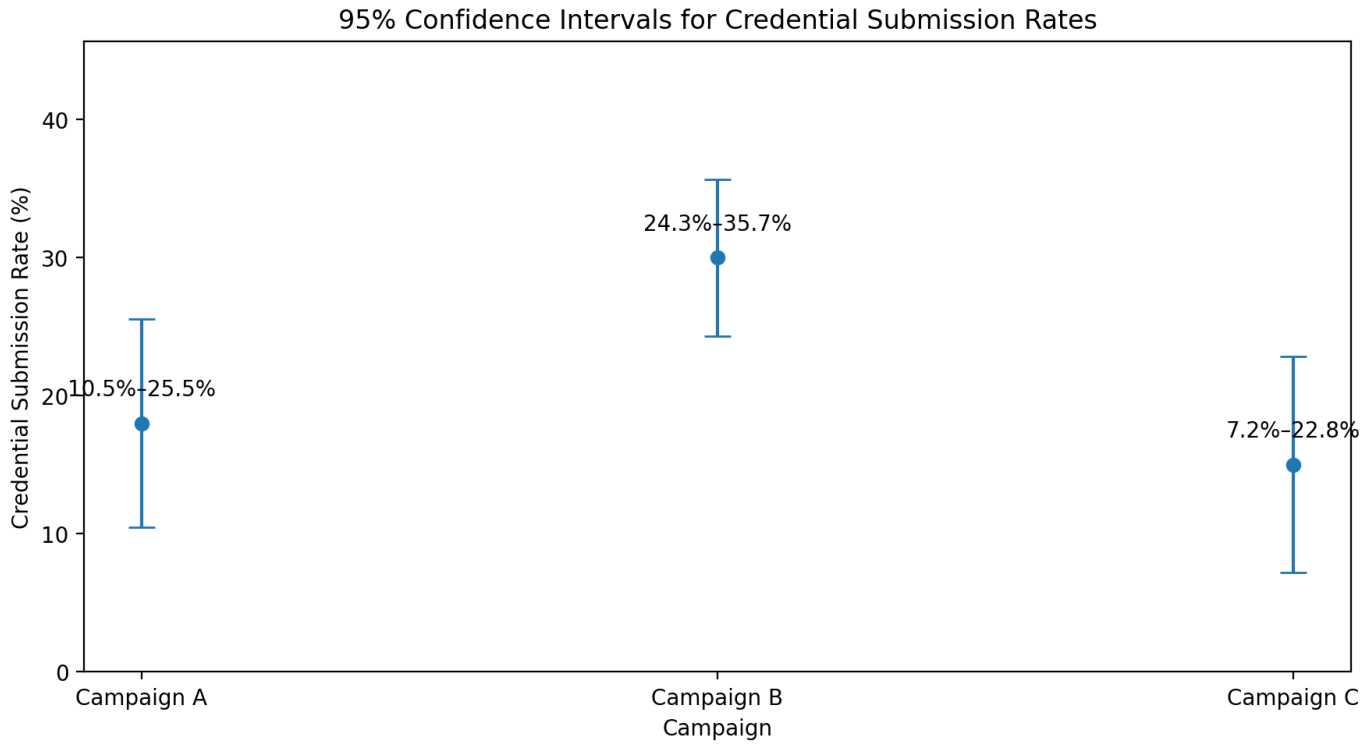
$= 0.1047$ to 0.2553

$= 10.5\%$ to 25.5%

3.4 Interpretation

Campaign A has a wider confidence range because it has a smaller sample size. This means there is more uncertainty in the result compared to Campaign B.

Campaign B has a narrower confidence interval because it tested more users. This makes its 30% credential submission rate more reliable for decision-making.



Phase 4: Executive Reporting

Executive Briefing Document

To:

Board of Directors, Chief Information Security Officer (CISO), Chief Financial Officer (CFO)

From:

GRC Risk Analysis Team

Date:

[Insert Current Date]

Subject:

Critical Phishing Risk Exposure Assessment and Financial Impact Analysis

1. Executive Summary

This report presents the results of a quantitative phishing risk assessment conducted across the organization. The analysis reveals a **critical level of exposure driven by human vulnerability to phishing attacks**.

The most effective phishing campaign, "IT System Password Reset," resulted in a **30% credential compromise rate**. When this behavior is projected across the organization's workforce of 2,000 employees, it results in:

- 600 potentially compromised user accounts
- 150 expected breach incidents
- An estimated **annual financial exposure of $652,500,000**

This level of risk is significantly higher than acceptable industry thresholds and requires **immediate and structured intervention**.

2. Key Quantitative Findings

Risk Metric	Value	Industry Average	Severity
Overall Credential Theft Rate	22.1%	15.3%	High
Maximum Campaign Success Rate	30%	18.7%	Critical
Annualized Loss Expectancy (ALE)	$652,500,000	$285,000,000	Severe
MFA Implementation ROI	724,175%	350%	Excellent

The organization's phishing exposure exceeds industry averages across all key metrics. This indicates:

- Employees are more likely to engage with phishing emails
- Attack success rates are significantly higher than expected
- Financial risk exposure is more than double industry benchmarks

3. Detailed Financial Analysis

3.1 Current Risk Position

The current risk posture is based on the results of the phishing simulation and subsequent financial modelling.

- Annualized Loss Expectancy (ALE): $652,500,000
- Expected Breach Incidents: 150
- Probability of Major Breach: 93.75%

- Per-Employee Risk Exposure: $326,250

The breach probability is calculated based on the likelihood that at least one of the expected breach incidents will occur. With 150 expected breaches, the probability of a major incident becomes extremely high.

The per-employee risk highlights the financial exposure associated with each user account within the organization.

3.2 Proposed Security Investment Portfolio

Control	Cost	Risk Reduction	Net Benefit	ROI	Priority
MFA Implementation	$90,000	$651,847,500	$651,757,500	724,175%	1
Enhanced Training	$100,000	$391,500,000	$391,400,000	391,400%	2
Email Filtering	$50,000	$130,500,000	$130,450,000	260,800%	3

Each control is evaluated based on:

- Cost of implementation
- Expected reduction in financial risk
- Net financial benefit
- Return on Investment (ROI)

MFA provides the highest impact because it directly prevents credential misuse, which is the primary attack success point.

Training reduces user susceptibility but does not eliminate risk entirely.

Email filtering provides an additional defensive layer but is less effective than user-focused controls.

4. Strategic Recommendations

4.1 Immediate Actions (Q1)

The following actions must be implemented without delay:

1. Deploy Multi-Factor Authentication across all users
    a. Cost: $90,000
    b. Impact: Near-total reduction in credential-based attacks
2. Launch targeted phishing simulation program
    a. Cost: $25,000

    b. Purpose: Continuous testing and awareness
3. Conduct emergency security awareness training
    a. Cost: $100,000
    b. Focus: High-risk departments and user groups

4.2 Strategic Initiatives (Full Year)

The following initiatives will strengthen long-term security posture:

1. Deploy advanced email security gateway
    a. Cost: $50,000
2. Establish continuous security monitoring
    a. Cost: $150,000
3. Implement security behaviour analytics
    a. Cost: $75,000

Immediate actions focus on **risk reduction**, while strategic initiatives focus on **long-term resilience**.

5. Expected Risk Posture After Controls

Metric	Current	With Controls	Reduction
Credential Theft Rate	22.1%	2.2%	90%
Annual Loss Expectancy	$652,500,000	$65,000,000	90%
Breach Probability	93.75%	25%	73.3%

After implementing the recommended controls:

- Credential theft is significantly reduced
- Financial exposure drops by approximately 90%
- Breach probability is brought to a manageable level

6. Investment Summary

- Total Investment Required: $490,000
- Total Risk Reduction: $587,500,000
- Net Financial Benefit: $587,010,000

Final Interpretation

The organization is currently exposed to extremely high financial risk due to phishing attacks.

However, this risk can be reduced dramatically with relatively low investment.

This demonstrates that:

- The problem is serious
- The solution is achievable
- The return on investment is exceptionally high

7. Final Executive Statement

The current cybersecurity posture exposes the organization to unacceptable financial risk driven by human vulnerability to phishing attacks.

Immediate implementation of Multi-Factor Authentication, supported by training and email security improvements, will significantly reduce this exposure.

Failure to act promptly may result in substantial financial loss and operational disruption.

Conclusion

This study successfully demonstrated the application of quantitative risk analysis in evaluating phishing-related cybersecurity threats within an organizational environment.

Through a structured approach, I was able to analyse user behaviour during phishing simulations, identify key points of vulnerability, and translate these behaviours into measurable financial risk. The results clearly show that human factors play a significant role in cybersecurity risk and can lead to substantial financial exposure if not properly managed.

The progression from basic behavioural metrics to organizational risk projection and financial impact analysis highlights the importance of aligning cybersecurity practices with business objectives. By calculating metrics such as credential submission rates and scaling them across the organization, it became possible to estimate realistic exposure levels and prioritize risks effectively.

The control evaluation further demonstrated that effective cybersecurity strategies must be both technically sound and economically justified. Controls such as Multi-Factor Authentication and security awareness training were shown to provide significant reductions in risk exposure, with exceptionally high returns on investment.

In addition, the use of statistical analysis introduced an important layer of reliability to the findings, ensuring that conclusions are not based solely on observed data but are supported by confidence-based reasoning.

In conclusion, this work reinforces the importance of adopting a data-driven and financially grounded approach to cybersecurity risk management. Organizations that quantify their risks and evaluate controls based on measurable impact are better positioned to make informed decisions, allocate resources effectively, and maintain a strong security posture.